

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	Make 2-3 notes of specific business requirements that will be analyzed. <i>The app will have to process financial transactions and has to be in compliance with PCI DSS. Profiles can be created by users internally and by connecting external accounts like google.</i>
II. Define the technical scope	List of technologies used by the application: ● Application programming interface (API) ● Public key infrastructure (PKI) ● SHA-256 ● SQL <i>APIs facilitate the building of applications by acting as the middle man between the user and the server and connecting to third parties to request information. They handle a lot of sensitive data and this is why the type of APIs used has to be well calculated, for example using private APIs for handling the financial transactions. Correct use of APIs will decrease the attack surface.</i>
III. Decompose application	 <pre> graph LR User[User] -- "Searching for sneakers for sale." --> Process((Product search process)) Process --> User Process -- "Listings of current inventory." --> Database[Database] Database --> Process </pre>
IV. Threat analysis	List 2 types of threats in the PASTA worksheet that are risks to the information being handled by the application. ● sql and command injection ● Session hijacking
V. Vulnerability analysis	List 2 vulnerabilities in the PASTA worksheet that could be exploited. ● Broken API token

	● <i>No prepared statements</i>
VI. Attack modeling	<pre> graph TD A[User data] --> B[SQL injection] A --> C[Session hijacking] B --> D[Lack of prepared statements] C --> E[Weak login credentials] </pre>
VII. Risk analysis and impact	List 4 security controls that you've learned about that can reduce risk. ● <i>SHA-256</i> ● <i>Password policies</i> ● <i>Least privilege</i> ● <i>Limiting requests</i>
